

Security+ 2.3 · Mobile Device Vulnerabilities

Mestre CyberSec · Lesson 2.3 — Mobile Device Vulnerabilities (3:23) · [Assistir Vídeo no YouTube ↗](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Celular: jailbreak (iOS) e rooting (Android) ROMPEM a sandbox e tiram proteções do vendor; sideloading = instalar fora da loja (malware). Defesa: MDM (gerencia central), bloquear jailbroken, app store verificado, container (separa trabalho/pessoal).

💡 Key Exam Highlights & Critical Concepts

- Jailbreak/rooting: tirou as proteções do fabricante — risco alto
- MDM: gerencia centralmente apps, config, wipe remotamente

🎯 Exam Tips & Typical CompTIA Scenarios

- 'bypasses manufacturer restrictions' = jailbreak/rooting
- 'installing apps outside official store' = sideloading

Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.3 — Mobile Device Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Jailbreaking

A privilege escalation attack that bypasses Apple iOS manufacturer restrictions, removing vendor protections such as the app sandbox, allowing unsigned apps, kernel access, and unauthorized app stores.

⚠ **Exam Trap:** 'Bypasses manufacturer restrictions' + iPhone/iOS = jailbreaking. Se a questão citar Android, a resposta é rooting — não troque o sistema operacional.

• Rooting

An Android-specific attack that gains administrator (root/superuser) privileges, breaking the vendor's security sandbox and enabling OS modification and installation of untrusted software.

⚠ **Exam Trap:** Rooting = Android; Jailbreaking = iOS. Ambos violam o modelo de segurança do fabricante — o dispositivo deve ser bloqueado/quarentenado via MDM.

• Sideload

Installing applications on a mobile device from sources outside the official/verified app store (e.g., third-party APK files), a common malware delivery vector on compromised or BYOD devices.

⚠ **Exam Trap:** 'Installing apps outside the official store' = sideloading. Mitigação: bloquear sideloading via MDM e permitir apenas app stores verificadas.

• Mobile Device Management (MDM)

A centralized administration framework used to enforce settings, applications, certificates, and security policies on mobile devices — including blocking jailbroken/rooted devices, deploying configuration, and performing remote wipe.

⚠ **Exam Trap:** Controle remoto central do dispositivo INTEIRO (gerenciar apps + config + wipe remoto + bloquear root) = MDM. Gerenciar apenas o aplicativo = MAM — distinção clássica de prova.

• Containerization (Secure Container)

Technology that separates corporate apps and data from personal data on the same mobile device, enabling controlled wipe of business content while personal information remains intact.

⚠ **Exam Trap:** Cenário BYOD: apagar dados corporativos SEM tocar nos dados pessoais = container (work profile). Wipe completo do dispositivo = MDM sem container — não confunda as escolhas.

• Sandboxing

Vendor-enforced isolation that keeps each app and process restricted to its own memory and data boundaries, preventing access outside the assigned space; jailbreaking/rooting removes this protection.

⚠ **Exam Trap:** Se a questão mencionar 'removes app isolation / breaks the security model / bypasses the vendor sandbox', o dispositivo está rooted/jailbroken — trate como comprometido.

• Custom ROMs

User-installed replacement of the stock operating system with modified firmware obtained outside official channels, which bypasses vendor security, lacks official updates, and may embed malicious code.

⚠ **Exam Trap:** 'Replaced/reflashed operating system' = custom ROM (Android). Modificação mais profunda que rooting e tipicamente viola a conformidade exigida pelo MDM.

• BYOD (Bring Your Own Device)

A policy allowing employees to use personal devices for corporate work, requiring controls such as secure containers, MDM enforcement, and blocking of rooted/jailbroken devices to mitigate mobile risks.

⚠ **Exam Trap:** Dispositivo pessoal + dados corporativos + necessidade de separar os mundos = BYOD com containerização. Evite responder 'wipe completo' quando há dados pessoais no aparelho.

✓ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

During a routine asset audit, a security analyst finds an employee's corporate-enrolled iPhone that can install apps from third-party sources and run unauthorized system-level tweaks that access files outside the app sandbox. Which term BEST describes the state of this device?

- A) Sideloaded
- B) Rooting
- C) Jailbreaking
- D) Installing a custom ROM

QUESTION 2 · EXAM SCENARIO

A logistics company issues Android phones to delivery drivers. The security team needs a solution to centrally enforce screen-lock policies, deploy Wi-Fi and VPN profiles, block app installs from unknown sources, and remotely wipe corporate data if a phone is lost. Which solution BEST meets these requirements?

- A) Mobile device management (MDM)
- B) Network access control (NAC)
- C) Containerization
- D) WPA3-Enterprise with a RADIUS server

QUESTION 3 · EXAM SCENARIO

An organization lets employees access corporate email and collaborate on documents from their personal phones under a BYOD program. The CISO wants corporate data isolated so a malicious personal app cannot read it, and the corporate data must be wipeable without touching personal photos and messages. Which approach BEST achieves this?

- A) Full-disk encryption
- B) Containerization with a secure container for corporate data
- C) Jailbreak detection with periodic compliance scans
- D) A full-device remote wipe policy for all BYOD users

QUESTION 4 · EXAM SCENARIO

A forensic review of an Android tablet shows that an attacker obtained a privileged shell and that applications were able to read and write to protected system partitions, far beyond normal app permissions. The owner admitted using a one-click exploit tool against the device months earlier. Which activity BEST explains this condition?

- A) Sideloaded
- B) Bluejacking
- C) Jailbreaking
- D) Rooting

QUESTION 5 · EXAM SCENARIO

Several employees installed a 'free premium' version of a popular office app by downloading an APK from a web forum instead of the official Play Store. Within days, those devices began exfiltrating contacts and credentials. Which term describes the installation method that allowed this, and its primary risk?

- A) Rooting — the tool granted the malware system-level privileges
- B) Sideloaded — installing outside the official store bypassed the store's vetting and delivered malware
- C) Containerization — corporate and personal data were mixed on the device
- D) Custom ROM flashing — the operating system was replaced with a vulnerable build

QUESTION 6 · EXAM SCENARIO

An MDM compliance check flags an employee's enrolled iPhone after detecting indicators consistent with a bypass of vendor protections and an unsigned package manager. Access to corporate mail and cloud resources is still active. Per the mobile security policy, what should the administrator do FIRST?

- A) Issue the user new credentials and continue monitoring the device
- B) Move the device's corporate data into a separate container
- C) Quarantine the device, blocking access to corporate resources until it is restored to a compliant state
- D) Add the device to a 30-day exception list while the user investigates

QUESTION 7 · EXAM SCENARIO

A company wants to adopt BYOD for field staff while keeping control of corporate email, documents, and Wi-Fi settings, but employees object to the IT department fully managing their personal phones. Which approach BEST balances corporate protection with personal privacy?

- A) Enroll devices in MDM and apply a work container that isolates corporate apps and data
- B) Require each employee to root the device so IT can enforce policies directly
- C) Restrict BYOD to jailbroken iPhones so policies can be pushed at the OS level
- D) Allow BYOD only over the guest Wi-Fi network without any device controls

QUESTION 8 · EXAM SCENARIO

A developer installed an unofficial, community-built replacement operating system on the personal Android phone he also uses to sync corporate email. Why does the security team consider this device non-compliant for accessing corporate resources?

- A) Custom ROMs use a weaker encryption algorithm than the stock operating system
- B) Community ROMs only allow the installation of apps from the vendor's store
- C) Custom ROMs disable all VPN capabilities required by the remote-access policy
- D) The ROM's integrity cannot be verified, and it may lack vendor security hardening, verified boot, and timely patches

QUESTION 9 · EXAM SCENARIO

After an incident, investigators review how malware reached a user's Android phone: a modified version of a well-known navigation app was hosted on a file-sharing site, and the user installed it after dismissing the warning displayed by the operating system. What does this scenario illustrate?

- A)** Rooting, because the attacker needed superuser rights to plant the app
- B)** A sandbox escape, because the malware read data from other applications
- C)** Sideloaded, because the store's review process was bypassed by installing the app from an untrusted source
- D)** BYOD abuse, because the device belongs to the employee

QUESTION 10 · EXAM SCENARIO

During new-hire security orientation, a colleague shows off an iPhone that runs apps from outside the official store and applies system-level tweaks. An employee asks what this modification does to the device's security compared with normal operation. Which response is MOST accurate?

- A)** Vendor-imposed restrictions are removed, granting privileged access and breaking the app sandbox that normally isolates apps and data
- B)** The device receives stronger, vendor-signed firmware with additional sandbox rules
- C)** The operating system is replaced entirely by a different mobile operating system
- D)** Only user-facing settings such as themes and default apps change; the security mechanisms remain intact

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Jailbreaking

Jailbreaking is the iOS-specific process of removing vendor-imposed restrictions to gain privileged control of the device, which breaks the sandbox and strips away vendor protections. Rooting is the equivalent activity on Android, sideloading only refers to installing apps outside the official store without necessarily altering the OS, and custom ROMs apply to Android devices, not iPhones.

Question 2: Option A — Mobile device management (MDM)

MDM provides centralized management of mobile devices: policy enforcement (passcodes, unknown-source restrictions), deployment of Wi-Fi/VPN profiles and certificates, and remote wipe of corporate data. Containerization only isolates corporate data without managing the whole device, NAC controls network admission but not device policy, and WPA3-Enterprise only secures network authentication.

Question 3: Option B — Containerization with a secure container for corporate data

Containerization creates an encrypted, isolated workspace for corporate apps and data on the personal device; access controls separate it from personal apps, and the MDM can selectively wipe only the container. Full-disk encryption protects data at rest but does not isolate apps from each other, jailbreak detection is only a compliance check, and a full-device wipe would destroy the employee's personal data.

Question 4: Option D — Rooting

Rooting is the Android equivalent of jailbreaking: it exploits the OS to gain privileged (root) access, removing app/user isolation and vendor protections so applications can access system partitions. Jailbreaking applies to iOS devices, sideloading only means installing apps from outside the official store, and bluejacking is sending unsolicited Bluetooth messages with no privilege impact.

Question 5: Option B — Sideloading — installing outside the official store bypassed the store's vetting and delivered malware

The employees sideloaded the app: they installed an APK from a third-party source rather than the Play Store, bypassing the store's review and signing checks, which makes sideloading a common malware delivery vector. Nothing in the scenario indicates rooting or a custom ROM was used, and containerization was never mentioned.

Question 6: Option C — Quarantine the device, blocking access to corporate resources until it is restored to a compliant state

Once a device shows signs of being jailbroken, vendor protections and the sandbox can no longer be trusted, so policy requires restricting or quarantining non-compliant devices until the stock OS is restored and the device passes compliance again. Reissuing credentials or granting an exception leaves a compromised device connected to corporate resources, and containerizing data on a compromised OS does not remove the underlying risk.

Question 7: Option A — Enroll devices in MDM and apply a work container that isolates corporate apps and data

The standard BYOD pattern is MDM enrollment combined with containerization: IT controls and can selectively wipe only the corporate workspace, while personal apps, photos, and settings remain private. Rooting or jailbreaking weakens security and would never be a requirement, and relying on guest Wi-Fi without device controls provides no protection for corporate data.

Question 8: Option D — The ROM's integrity cannot be verified, and it may lack vendor security hardening, verified boot, and timely patches

Replacing the vendor OS with a custom ROM — which typically requires unlocking the bootloader — removes the chain of trust: the build's integrity cannot be verified, vendor sandbox hardening and security patches may be missing or delayed, and the device may hide its state from compliance tools. Encryption strength is not the core issue, and a non-verifiable OS increases, not decreases, exposure.

Question 9: Option C — Sideloading, because the store's review process was bypassed by installing the app from an untrusted source

The distribution model was sideloading: the user installed an APK outside the official store after overriding the unknown-source warning, bypassing the store vetting that could have blocked the trojanized app. Nothing indicates rooting was used to

plant the app, no sandbox escape is demonstrated, and device ownership is irrelevant to the attack vector.

Question 10: Option A — Vendor-imposed restrictions are removed, granting privileged access and breaking the app sandbox that normally isolates apps and data

Jailbreaking removes the vendor's restrictions, giving users and apps privileged access to parts of the OS that the sandbox and code signing normally protect — which is exactly why jailbroken devices are treated as untrusted. It does not add vendor protections, it does not convert the device to another OS (that describes custom ROMs on Android), and it changes core security mechanisms, not just cosmetic settings.